

SQL 注入 (SQL Injection) 技术说明

1. 概述

SQL 注入 (SQL Injection) 是一种最常见的 Web 应用安全漏洞，属于 OWASP Top 10 (2021) 中 **A03: Injection** 类别。攻击者通过向用户输入接口插入恶意 SQL 语句，欺骗后端数据库执行非预期的查询或操作，从而达到窃取数据、篡改数据、提权乃至控制服务器的目的。

2. 原理与分类

2.1 基本原理

Web 应用未对用户输入进行充分校验或参数化处理，直接将输入拼接进 SQL 语句，导致数据库将恶意输入解释为 SQL 命令的一部分执行。

2.2 常见分类

类型	特点	常见场景
联合查询注入 (Union-based)	利用 UNION 拼接额外查询结果	有显式回显的查询接口
报错注入 (Error-based)	通过数据库错误信息推断数据	错误信息回显到前端
布尔盲注 (Boolean-based)	通过页面真/假响应逐位推断	无显式回显但有条件差异
时间盲注 (Time-based)	通过延时响应逐位推断	无任何回显差异
堆叠查询注入 (Stacked Queries)	执行多条 SQL 语句	数据库支持多语句执行

类型	特点	常见场景
二阶注入 (Second Order)	恶意数据先存储，后续操作触发	数据先写入后在其他功能处调用

3. 攻击示例

3.1 联合查询注入

```
正常请求: /user?id=1001
SQL: SELECT * FROM users WHERE id = 1001

注入请求: /user?id=1001 UNION SELECT username, password FROM admin
SQL: SELECT * FROM users WHERE id = 1001 UNION SELECT username, password FROM admin
```

3.2 布尔盲注

```
注入请求: /user?id=1 AND SUBSTRING((SELECT password FROM admin LIMIT 1),1,1)='a'
响应: 200 OK (存在) → 第一位密码字符为 'a'
```

3.3 堆叠查询

```
注入请求: id=1001; DROP TABLE users; --
SQL: SELECT * FROM users WHERE id = 1001; DROP TABLE users; --
```

4. 危害与影响

危害等级	具体影响
严重	数据库被完全控制，数据全量泄露，服务器被植入后门
高危	用户敏感数据（密码、身份证、银行卡）被拖库
中危	部分数据被篡改，业务功能异常
低危	仅能获知数据库版本、表结构等基础信息

真实案例

- 2014 年：某知名电商平台因 SQL 注入导致 1.2 亿条用户数据泄露
- 2021 年：某财政系统 SQL 注入漏洞导致数百万纳税人信息泄露
- 2022 年：某车企 App 联合查询注入可查询任意车主实名信息

5. 防御措施

5.1 技术防御

措施	说明	优先级
参数化查询 (Prepared Statement)	SQL 结构与数据分离，最根本的防御	★★★★★ ★ 必须实施
ORM 框架	使用 Hibernate、MyBatis 等成熟的 ORM，规避拼接 SQL	★★★★★
输入校验	白名单校验、特殊字符转义、类型强制转换	★★★★★ ☆
最小权限原则	Web 应用数据库账号仅授权必要表的 SELECT/INSERT/UPDATE	★★★★★ ☆
WAF	部署 Web 应用防火墙拦截常见注入 Payload	★★★★☆ ☆
数据库执行白名单	限制存储过程调用、禁用 xp_cmdshell 等危险功能	★★★★☆ ☆
定期漏扫	通过 AWVS、SQLMap、AppScan 等工具周期性扫描	★★★★★ ☆

5.2 开发规范

- 1. **禁止**直接拼接 SQL 字符串，强制使用参数化查询
- 2. **禁止**在错误信息中暴露 SQL 语句或数据库版本
- 3. **禁止**以超级管理员（SA/DBA）账户连接 Web 应用
- 4. **必须**对用户输入做长度、类型、格式校验
- 5. **必须**定期审查代码中的 SQL 写法

5.3 检测与监控

- 部署 RASP（运行时应用自我保护）实时检测注入行为
- 开启数据库审计日志，记录非授权查询
- 对异常 SQL 模式（OR 1=1、UNION SELECT、延时函数）设置告警

6. 合规要求

根据《中华人民共和国网络安全法》及等保 2.0 标准：

法规	要求
《网络安全法》第二十五条	采取技术措施防范计算机病毒和网络攻击、侵入
《网络安全法》第五十九条	未履行安全保护义务的，责令改正并处罚款
等保 2.0 三级—安全计算环境	应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求
等保 2.0 三级—安全开发	应进行代码审查，对代码中可能存在的注入类漏洞进行检查
《数据安全法》第二十七条	应当采取必要措施保障数据安全

整改时限建议： - SQL 注入类高危漏洞：**发现后 24 小时内**制定修复方案，**72 小时内**完成修复 - 无法立即修复的：须部署 WAF 临时阻断规则，在 **7 天内**完成代码层面彻底修复

7. 总结

SQL 注入是最经典也最危险的 Web 安全漏洞之一，攻击成本低而危害极大。防御的核心在于**参数化查询**和**最小权限原则**，配合定期扫描和 WAF 形成纵深防御体系。开发阶段即应将 SQL 注入防御纳入编码规范，避免上线后被动修补。

本文档由企业安全智能助手生成，数据来源：安全知识库与公开威胁情报。